



INCIDENT MANAGEMENT & RESPONSE · WEEK 7 · DAY 12

Network Security Incidents

DoS, DDoS, MITM, Port Scanning & Unauthorized Access

5-hour class · 5 lessons · Detection → Triage → Coordination → Recovery



Cyber.SoHo Educational Hub

From the Industry to the Classroom — Building the IT's Future, Today and Together!

Welcome Back, Team

Today we move from theory to operations.

- Week 6 covered the mid-term review and Incident Management foundations.
- Week 7 — Day 12 (today) — focuses on the most common, most disruptive, and most reported category: network-based incidents.
- Denial of Service (DoS), Distributed Denial of Service (DDoS), Man-in-the-Middle (MITM), reconnaissance, and unauthorized access account for the majority of incidents reported to national CSIRTs.
- By the end of this class, you will be able to triage, escalate, and recover from these incidents using a single coherent framework.



Today's Five Lessons

- Lesson 1 — Categorize network-based attacks (DoS, DDoS, MITM, port scanning, unauthorized access)
- Lesson 2 — Map common attack vectors and exploitation techniques per Open Systems Interconnection (OSI) layer
- Lesson 3 — Perform initial detection and triage using logs and alerts
- Lesson 4 — Coordinate with Internet Service Providers (ISPs) and external parties during large-scale or multi-vector attacks
- Lesson 5 — Apply eradication and recovery strategies to restore network integrity post-incident

 *Goal — Move from "the network is on fire" to "contained, eradicated, and verifiably clean" — with an auditable paper trail.*



01

Categorize Network-Based Attacks

DoS, DDoS, MITM, Port Scanning & Unauthorized Access

What Is a Network-Based Attack?

A network-based attack abuses the protocols, services, or pathways that make networks work — not application-logic flaws.

Key distinction

- Application attacks target what an app does (e.g., SQL injection in a login form).
- Network attacks target how traffic gets to the app (e.g., overwhelming the network so the login form is unreachable).
- The two often happen together — but require very different containment playbooks.



The Five Families We Cover Today (1/2)

Denial of Service (DoS)

A single source overwhelms a target with traffic or malformed requests.

Telltale: high volume from one IP, drops in service availability.

Goal: outage. Often a smokescreen for a second, quieter attack.

Distributed DoS (DDoS)

A botnet of thousands of sources overwhelms a target.

Telltale: massive volume from geographically dispersed IPs.

Goal: outage at scale. Volumetric, protocol, or application-layer.

Man-in-the-Middle (MITM)

Attacker sits between two parties, reads or modifies traffic.

Telltale: certificate anomalies, ARP table drift, unexpected gateway.

Goal: theft of credentials, session tokens, or data in transit.



The Five Families We Cover Today (2/2)

Port Scanning / Recon

Adversary maps your attack surface, services, and versions.

Telltale: SYN packets to many ports from one source in short window.

Goal: pre-exploitation. Treat as the early warning, not the incident.

Unauthorized Access

Credential abuse, lateral movement, privilege escalation.

Telltale: anomalous logons, off-hours, geographically impossible.

Goal: persistence on internal systems, data exfiltration.



Why Categorize Before You Contain

- Each family has a different signature — a different log shape, a different correlation pattern.
- Each family has a different containment playbook — block at firewall, rotate credentials, or call the ISP.
- Each family has a different external party — scrubbing provider, identity team, law enforcement.
- The wrong playbook on the right incident burns time and can make things worse (e.g., resetting passwords during a DDoS does nothing).
- Categorization is the first 5 minutes of any incident — and the highest-leverage 5 minutes of the whole response.



Family → Telltale → Who You Call

Family	Primary telltale	Who you call
DoS / DDoS	Massive volume, low session quality	ISP + scrubbing provider
Man-in-the-Middle (MITM)	Certificate anomalies, ARP drift	Internal SOC + endpoint team
Port Scan / Recon	SYN-to-many-ports from one source	Firewall / network team
Unauthorized Access	Anomalous logons, off-hours, geo-impossible	Identity team + legal
Multi-vector (combined)	Two or more signatures concurrent	Incident Commander coordinates all

Key Takeaway



Categorize before you contain. The wrong playbook on the right incident makes things worse — every time.



02

Attack Vectors Across the OSI Layers

Use the OSI model as a diagnostic grid, not just a teaching tool

The OSI Model as an Incident Response Map

The Open Systems Interconnection (OSI) model is a diagnostic grid for incidents — not just a teaching tool.

- Every alert lives on one or more OSI layers.
- Naming the layer first answers three operational questions immediately:
 - Which logs are authoritative?
 - Which team owns containment?
 - Can the ISP help, or is this an internal-only fight?
- ISO/IEC 7498-1 defines the model. We use it every shift.



The Seven OSI Layers — Upper Stack

L7

Application

HTTP, DNS, SMTP — what users and apps see directly.

L6

Presentation

Transport Layer Security (TLS), encryption, encoding, compression.

L5

Session

Session establishment, tokens, Remote Procedure Call (RPC).

L4

Transport

Transmission Control Protocol (TCP), User Datagram Protocol (UDP), ports.



The Seven OSI Layers — Lower Stack

L3

Network

Internet Protocol (IP), routing, Border Gateway Protocol (BGP).

L2

Data Link

Ethernet, Address Resolution Protocol (ARP), switching, VLANs.

L1

Physical

Cabling, radio, ports, signal — the bits on the wire or in the air.

Tip — Most volumetric DDoS hits Layers 3–4. Most application-layer DDoS hits Layer 7. MITM usually lives at Layers 2–3 (ARP, IP) or Layer 6 (TLS downgrade).



Common Vectors Per Layer — Upper Stack

Layer	Example attack	Quick defensive control
L7 — Application	HTTP flood, DNS amplification	Web Application Firewall (WAF), rate limiting
L6 — Presentation	TLS downgrade, weak cipher abuse	Pin modern cipher suites, HSTS
L5 — Session	Session hijacking, token replay	Short-lived tokens, re-auth on sensitive actions
L4 — Transport	SYN flood, UDP flood, port scan	SYN cookies, connection rate limits



Common Vectors Per Layer — Lower Stack

Layer	Example attack	Quick defensive control
L3 — Network	IP spoofing, BGP hijack	Reverse Path Forwarding (RPF), Resource Public Key Infrastructure (RPKI)
L2 — Data Link	ARP poisoning, VLAN hopping	Dynamic ARP Inspection (DAI), port security
L1 — Physical	Cable tap, rogue access point	Physical access control, RF surveys

ISP help is realistic for L3–L4, sometimes for L7, almost never for L2 or L1.

Why Layer-Awareness Speeds Up Triage

First analyst question on every alert:

"Which OSI layer (or layers) is this hitting?"

Naming the layer drives three follow-up answers in seconds, not minutes:

- Which logs are authoritative for this layer (firewall vs. IDS vs. auth vs. switch)?
- Which team owns containment (network, endpoint, identity, or facilities)?
- Which external party can help (ISP, scrubber, vendor, none)?



Key Takeaway



Every alert lives on one or more OSI layers. Naming the layer first cuts triage time in half.

03

Detection & Triage

From firehose of alerts to a ranked queue of confirmed incidents

The Three Pillars of Network Detection

Pillar 1

Firewall / Edge Logs

What entered or exited.

Direction, source, destination, port, protocol, action (allow/deny).

First place to look for volumetric anomalies.

Pillar 2

IDS / IPS Alerts

What looked malicious.

Intrusion Detection and Prevention System signatures, anomaly scores, rule IDs.

First place to look for known attack patterns.

Pillar 3

Authentication Logs

Who tried to log in.

User, source IP, success/failure, multi-factor result, geography.

First place to look for unauthorized access.

A single source lies. Two sources correlate. Three sources convict.



Triage Step 1 — Validate

Is this a real event, or a false positive?

- Confirm the timestamp against a second source (network device clock vs. SIEM clock).
- Confirm the source IP, asset, and user (against asset inventory and identity store).
- Reproduce the indicator from a primary log, not from the alert summary alone.
- Rule out maintenance, scheduled scans, or known business behaviour before declaring an incident.
- If you cannot validate within 10 minutes, mark as suspected and continue to Step 2 — do not stall.



Triage Step 2 — Score Severity

Use a consistent rubric. The most common SIEM formula:

$$\text{Severity} = \text{Asset_Criticality} \times \text{Threat_Confidence} \times \text{Blast_Radius} \times \text{Reversibility}$$

- Asset_Criticality — how valuable is the target? (1 = lab box, 5 = production database)
- Threat_Confidence — how sure are we this is malicious? (1 = anomaly, 5 = signature match + multi-source)
- Blast_Radius — how many users/systems are exposed? (1 = single host, 5 = whole tenant)
- Reversibility — how hard to undo damage? (1 = trivial, 5 = data destroyed or exfiltrated)



Triage Step 3 — Classify Priority

1

P1 — Critical

Confirmed incident, high severity. Page the on-call commander now. Notification clock starts. Begin containment.

2

P2 — High

Confirmed incident, medium severity. Ticket assigned within 1 hour. Containment within the shift.

3

P3 — Investigation

Suspected, unconfirmed. Investigate within 24 hours. Promote or close based on findings.

4

FP — False Positive

Confirmed not malicious. Close with reason code. Tune the rule so the same FP does not recur.



Why a 5-Minute Correlation Window?

- Most multi-source attacks bunch their telltales within minutes:
 - Port scan precedes exploit attempt by seconds to minutes.
 - Failed logons cluster within a few minutes (then a successful one — or none).
 - DDoS amplification ramps from baseline to peak over 1–3 minutes.
- A 5-minute window is wide enough to catch correlated bursts and narrow enough to keep false-positive noise down.

 *Rule of thumb — Correlate events on the same source IP within a 5-minute rolling window. Tune from there based on environment noise.*



Key Takeaway



A SIEM is only as good as its correlation rules. Without them, you have a very expensive log archive — not a detection engine.

04

Coordination with ISPs & External Parties

Knowing the ladder — and how to climb it without skipping rungs

When You Cannot Solve It Alone

Some attacks exceed your perimeter's capacity, your team's authority, or your legal scope. You will need help.

- Volumetric DDoS that saturates your uplink — your firewall cannot help if the pipe is full upstream.
- Multi-jurisdictional attacker — investigation requires law enforcement coordination.
- Personal-data exposure — privacy regulators must be notified within statutory windows.
- Anything triggering insurance cover — carriers require notification within 24–72 hours.



External Parties — Who and Why (1/2)

Internet Service Provider (ISP)

Bell, Rogers, TELUS, Cogeco, AT&T Business, Verizon Business, Lumen. Upstream filtering and Remote Triggered Black Hole (RTBH).

DDoS Scrubbing Service

Cloudflare Magic Transit, Akamai Prolexic, Amazon Web Services (AWS) Shield Advanced. Diverts and cleans traffic.

National CSIRT

Canadian Centre for Cyber Security (CCCS); Cybersecurity and Infrastructure Security Agency (CISA) in the United States.

Law Enforcement

Royal Canadian Mounted Police National Cybercrime Coordination Centre (RCMP NC3); FBI Internet Crime Complaint Center (IC3).



External Parties — Who and Why (2/2)

Privacy Regulator (CA)

Office of the Privacy Commissioner (OPC) — federal; Commission d'accès à l'information du Québec (CAI) under Law 25.

Privacy Regulator (US)

State attorneys general; Department of Health and Human Services Office for Civil Rights (HHS OCR) for HIPAA-covered data.

Cyber Insurance Carrier

Most policies mandate notification within 24–72 hours. Failure to notify can void coverage.

Sectoral Regulator (if any)

Financial, healthcare, critical infrastructure — Office of the Superintendent of Financial Institutions (OSFI), sector-specific bodies.



The Escalation Ladder

Internal Security Operations Center (SOC)



Internet Service Provider (ISP) Network Operations Center (NOC)



Specialized DDoS Scrubber



National CSIRT (CCCS, CISA)



Law Enforcement (RCMP NC3, FBI IC3)



Privacy Regulator (if personal data implicated)



Cyber Insurance Carrier



What to Have Ready Before You Call

Every external party asks the same first questions. Have these ready:

- Public IP ranges affected — and your Autonomous System Number (ASN)
- Approximate attack volume — packets per second and bits per second
- Attack vector — OSI layer, protocol, source geography if known
- Your point of contact — name, phone, email, after-hours number
- Your internal case / ticket reference number — for cross-system traceability
- Pre-printed escalation contact card — pinned in the SOC, with after-hours numbers verified quarterly



Key Takeaway



External parties move at the speed of your preparedness. A 30-second elevator pitch beats a 30-minute back-and-forth.



05

Eradication & Recovery

Closing the loop — and making the next incident shorter

The NIST Incident Response Lifecycle

Per NIST Special Publication 800-61 Revision 2:

1

Preparation

Policies, tools, playbooks, training, baselines.

2

Detection & Analysis

Identify and validate. Lessons 1–3 above.

3

Containment, Eradication & Recovery

Stop, remove, restore. ← we are here.

4

Post-Incident Activity

Lessons learned, metrics, control updates.



Eradication — Get the Adversary Out

Containment stops the bleeding. Eradication removes the cause.

-  Rotate every credential the adversary could have touched (service accounts included).
-  Re-image — do not "clean" — compromised hosts. Memory-resident threats survive cleaning.
-  Block indicators of compromise (IPs, domains, file hashes) at firewall, DNS, and endpoint.
-  Purge persistence mechanisms — scheduled tasks, services, startup items, cron jobs, run keys.
-  Patch the vulnerability that let them in. If you skip this, you will see them again.

Recovery — Restore With Confidence

Recovery is verified return to known-good state — not "flip the switch back on."

-  Restore from clean, dated backups — verified pre-incident.
-  Run a post-restore integrity sweep — file hashes, service inventory, port inventory.
-  Compare against a baseline captured before the incident.
-  Keep enhanced monitoring active for 30–90 days post-recovery.
-  Document every restored asset with date, source backup, and verification result.

Post-Incident Review — Within 2 Weeks

Held within 2 weeks of incident closure. Mandatory attendees:

- Incident Commander — owns the meeting agenda and follow-ups.
- Lead analyst(s) — present the timeline and the technical detail.
- Affected business owner(s) — represent operational and customer impact.
- Legal and / or compliance representative — confirm notification obligations are closed.
- Communications representative — if there was any external messaging during the incident.



The Five Questions Every Review Must Answer

1

What happened, on what timeline?

Reconstruct the incident as a sequence — detection, response, containment, recovery.

2

What worked in our response?

Identify reusable wins. Name people and decisions, not just tools.

3

What did not work, and why?

Process gaps, tool gaps, knowledge gaps. No blame — focus on systems.

4

What will we change?

Process, control, training, runbook, or policy. Concrete, not aspirational.

5

Who owns each change, by when?

Every change has a named owner and a target date. Tracked to closure.



Key Takeaway



Recovery without a post-incident review is lost institutional learning. The same incident will recur — guaranteed.



06

Wrap-Up

Recap, references, and what you walk away with

What You Should Now Be Able to Do

-  Name the five families of network attacks and their primary signatures.
-  Map any alert onto the Open Systems Interconnection (OSI) layer(s) it touches.
-  Triage multi-source events using validation → severity → priority.
-  Escalate to the right external party — with the right facts ready in 30 seconds.
-  Eradicate properly (rotate / reimage / block / purge / patch) and recover with verification.
-  Run a post-incident review that produces durable, owned change.

Key Frameworks & Standards Cited Today

- NIST Special Publication 800-61 Revision 2 — Computer Security Incident Handling Guide
- NIST Cybersecurity Framework (CSF) 2.0 — Govern, Identify, Protect, Detect, Respond, Recover
- MITRE ATT&CK — adversary tactic and technique knowledge base (including TA0003 Persistence)
- ISO/IEC 27035 — information security incident management
- ISO/IEC 7498-1 — the Open Systems Interconnection (OSI) reference model
- Forum of Incident Response and Security Teams (FIRST) — Common Vulnerability Scoring System (CVSS), Traffic Light Protocol (TLP)



Tools Named Today — All Vendor-Neutral and Public

Detection / Sensors

- Wazuh — open-source SIEM and Host-based IDS
- Splunk — commercial SIEM
- IBM QRadar — enterprise SIEM
- Microsoft Sentinel — cloud-native SIEM
- Elastic Security — open-source stack
- Zeek — network security monitor
- Snort, Suricata — IDS/IPS engines

Mapping & Mitigation

- Nmap, Masscan — network mapping
- Wireshark — packet analysis
- Cloudflare Magic Transit — DDoS scrubbing
- Akamai Prolexic — DDoS scrubbing
- AWS Shield Advanced — DDoS protection
- Lynis — Linux hardening audit
- ClamAV — open-source antivirus



Today's Deliverables — On the Course Portal

-  Full lecture in Markdown — every concept, scenario, and code example annotated.
-  OSI Attack Vectors spreadsheet — 3 sheets (Vectors, Categories, Severity Calculator).
-  Attack-taxonomy and triage-decision-tree diagrams (SVG).
-  SYN-flood detector (Python) — Lesson 1.
-  Layer-by-layer OSI posture check (Bash) — Lesson 2.
-  Multi-source triage aggregator (Python) — Lesson 3.
-  Offline-capable escalation checklist (HTML) — Lesson 4.
-  Recovery verification sweep (PowerShell) — Lesson 5.

Disclaimer, Intellectual Property & Liability

- All content © Cyber.SoHo Educational Hub. Cyber is the sole intellectual property owner.
- Not affiliated with, sponsored by, or endorsed by any third-party organization, vendor, or institution named. Trademarks are property of their respective owners.
- Code samples are defensive and educational. Misuse may violate:
 - Canadian Criminal Code section 342.1 (Unauthorized use of computer)
 - United States Computer Fraud and Abuse Act (CFAA), 18 U.S.C. § 1030
 - European Union Directive 2013/40/EU on attacks against information systems
 - Spanish Ley Orgánica 10/1995 (Código Penal), articles 197 and 264
- Always operate within written authorization. Follow ACM and IEEE professional ethics codes.
- Always verify external links via VirusTotal (<https://www.virustotal.com/>) before clicking.





Cyber.SoHo Educational Hub

From the Industry to the Classroom

Building the IT's Future, Today and Together!